Уязвимости: классификация, оценка, управление

План лекции

Уязвимости:

- Классы
- Рейтинги
- Идентификаторы
- Базы данных
- Оценка
- Управление

Вспомним

- Где безопаснее хранить токен авторизации — в localStorage или в httpOnly cookie?
- Уязвимую библиотеку подключили в проект. Какая практика и на каком этапе SDLC должна была это поймать?
- Чем AppSec-инженер отличается от пентестера?

Классы уязвимостей

Common Weakness Enumeration

CWE — реестр типовых классов уязвимостей на уровне паттерна, независимо от конкретного продукта или технологии

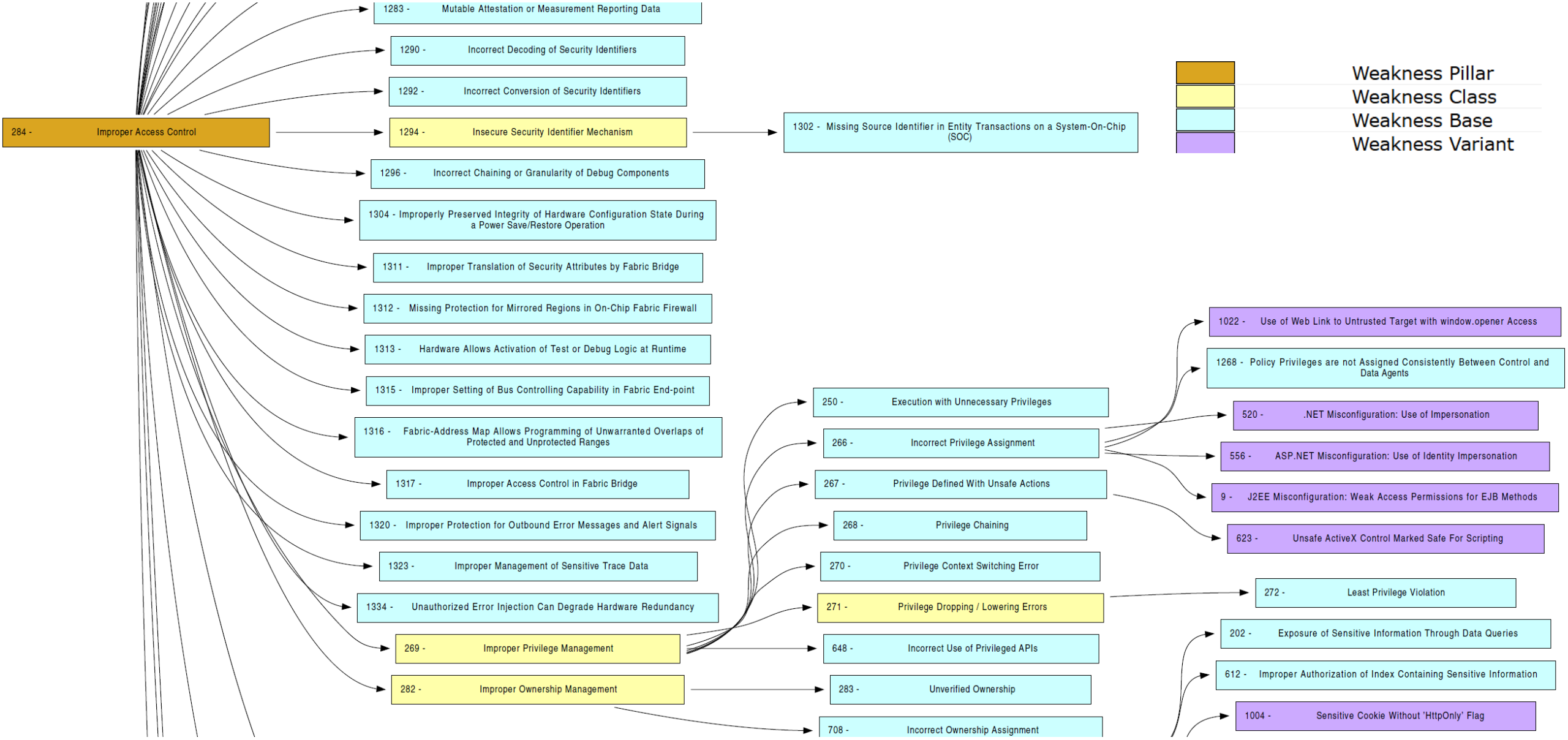
CWE-863: Incorrect Authorization

Weakness ID: 863
Vulnerability Mapping: ALLOWED (with careful review of mapping notes)
Abstraction: Class

Description

The product performs an authorization check when an actor attempts to access a resource or perform an action, but it does not correctly perform the check.





https://cwe.mitre.org/data/pdfs.html

CWE-284: Improper Access Control

Weakness ID: 284
Vulnerability Mapping: DISCOURAGED
Abstraction: Pillar

Description

The product does not restrict or incorrectly restricts access to a resource from an unauthorized actor.

Pillar - самый широкий уровень
Описывает общую природу проблемы

CWE-285: Improper Authorization

Weakness ID: 285
Vulnerability Mapping: DISCOURAGED
Abstraction: Class

Description

The product does not perform or incorrectly performs an authorization check when an actor attempts to access a resource or perform an action.

Class - уровень конкретнее
Указывает механизм или тип операции, где возникает проблема

CWE-863: Incorrect Authorization

Weakness ID: 863
Vulnerability Mapping: ALLOWED (with careful review of mapping notes)
Abstraction: Class

Description

The product performs an authorization check when an actor attempts to access a resource or perform an action, but it does not correctly perform the check.

Base – наиболее конкретный, узнаваемый паттерн, который можно встретить в коде

CWE-639: Authorization Bypass Through User-Controlled Key

Weakness ID: 639
Vulnerability Mapping: ALLOWED
Abstraction: Base

Description

The system's authorization functionality does not prevent one user from gaining access to another user's data or record by modifying the key value identifying the data.

Пример – IDOR

```
GET /api/orders/{id}

query = "SELECT * FROM orders
WHERE id = " + id;
db.execute(query)
```

- Уязвимость: **IDOR - Insecure direct object reference**
- Проверка прав доступа отсутствует или работает неверно
- Идентификатор: **CWE-639** Authorization Bypass Through User-Controlled Key
- Pillar: **CWE-284** Improper Access Control

Пример – SQL Инъекция

```
GET /api/orders/{id}

query = "SELECT * FROM orders
WHERE id = " + id;
db.execute(query)
```

- Уязвимость: **SQL Injection**
- Пользовательский ввод попадает в запрос или команду без нейтрализации
- Класс: **CWE-89** SQL Injection
- Pillar: **CWE-707** Improper Neutralization

Рейтинги уязвимостей

Рейтинги уязвимостей

Зачем нужны рейтинги

Рейтинг помогает распределить время и усилия команды безопасности между возможными классами уязвимостей, выделяя приоритетные

Как составляются рейтинги

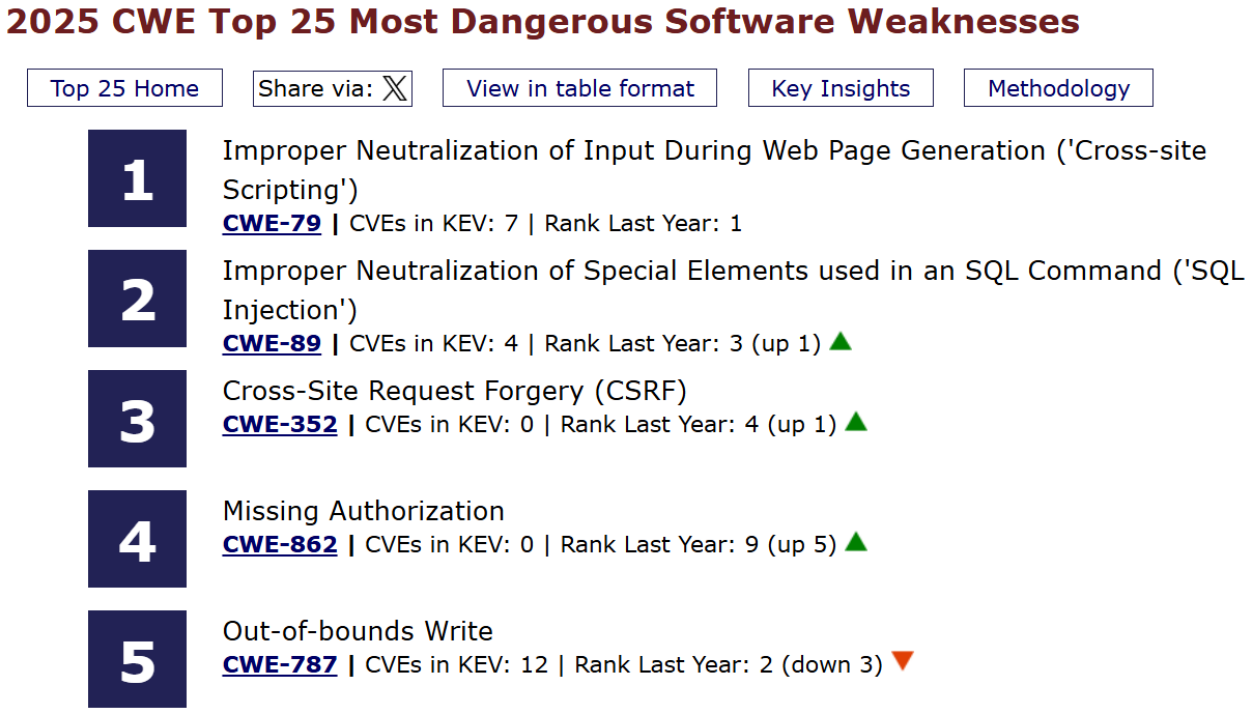
- Рейтинг строится на статистике реальных инцидентов
- В него попадают классы уязвимостей, которые встречаются чаще всего и наносят наибольший ущерб в определенном контексте (веб-приложения, API, мобильные приложения, LLM)
- Данные собирают из отчетов о найденных уязвимостях, bug bounty программ, тестирования на проникновение



CWE Top 25

CWE Top 25 - ежегодный список самых опасных классов уязвимостей, составленный MITRE на основе реальных данных об эксплуатации

Источник данных - записи CVE за последние годы, каждая привязана к своему CWE. Для каждого CWE считается частота встречаемости среди реальных уязвимостей и средняя серьезность этих случаев



2025 CWE Top 25 Most Dangerous Software Weaknesses

Top 25 Home | Share via: X | View in table format | Key Insights | Methodology

1. Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')
   CWE-79 | CVEs in KEV: 7 | Rank Last Year: 1
2. Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
   CWE-89 | CVEs in KEV: 4 | Rank Last Year: 3 (up 1) ▲
3. Cross-Site Request Forgery (CSRF)
   CWE-352 | CVEs in KEV: 0 | Rank Last Year: 4 (up 1) ▲
4. Missing Authorization
   CWE-862 | CVEs in KEV: 0 | Rank Last Year: 9 (up 5) ▲
5. Out-of-bounds Write
   CWE-787 | CVEs in KEV: 12 | Rank Last Year: 2 (down 3) ▼

OWASP Web Top 10

OWASP Web Top 10 - список из 10 самых критичных категорий риска для веб-приложений, составленный проектом OWASP

Каждая позиция - широкая категория риска, объединяющая несколько связанных CWE. Список выходит раз в несколько лет. Актуальная редакция 2025 г.

Top 10:2025 List

1. A01:2025 - Broken Access Control
2. A02:2025 - Security Misconfiguration
3. A03:2025 - Software Supply Chain Failures
4. A04:2025 - Cryptographic Failures
5. A05:2025 - Injection
6. A06:2025 - Insecure Design
7. A07:2025 - Authentication Failures
8. A08:2025 - Software or Data Integrity Failures
9. A09:2025 - Security Logging and Alerting Failures
10. A10:2025 - Mishandling of Exceptional Conditions

https://owasp.org/www-project-top-ten/

Использование рейтингов в работе

- **Чеклист для планирования тестирования**
  Ориентир: с каких категорий риска начинать план проверки
- **Единая нумерация**
  Разработчик, тестировщик и AppSec-инженер ссылаются на одну и ту же нумерацию. Сканеры (SAST, DAST) размечают найденные уязвимости категориями
- **Основа для требований безопасности**
  Рейтинг как источник требований безопасности при проектировании новой функциональности

! Этих категорий недостаточно для полноценного покрытия приложения безопасностью

Остальные рейтинги OWASP

- OWASP API Security Top 10 — https://owasp.org/www-project-api-security
- OWASP Mobile Top 10 — https://owasp.org/www-project-mobile-top-10
- OWASP Top 10 for Business Logic Abuse - https://owasp.org/www-project-top-10-for-business-logic-abuse/
- OWASP Top 10 for LLM Applications — https://owasp.org/www-project-top-10-for-large-language-model-applications
- OWASP Top 10 for Kubernetes — https://owasp.org/www-project-kubernetes-top-ten

OWASP - Open Worldwide Application Security Project

Некоммерческое международное сообщество специалистов по безопасности приложений

- **Рейтинги рисков:** Top 10 Web, API, Mobile, LLM
- **Стандарты и модели зрелости:** SAMM, ASVS (Application Security Verification Standard)
- **Инструменты:**
  Dependency-Check (сканер зависимостей)
  Noir (сканер исходных точек)
- **Обучение:**
  Cheat Sheet Series - короткие практические шпаргалки,
  Juice Shop - специально уязвимое приложение для тренировки

Идентификаторы уязвимостей

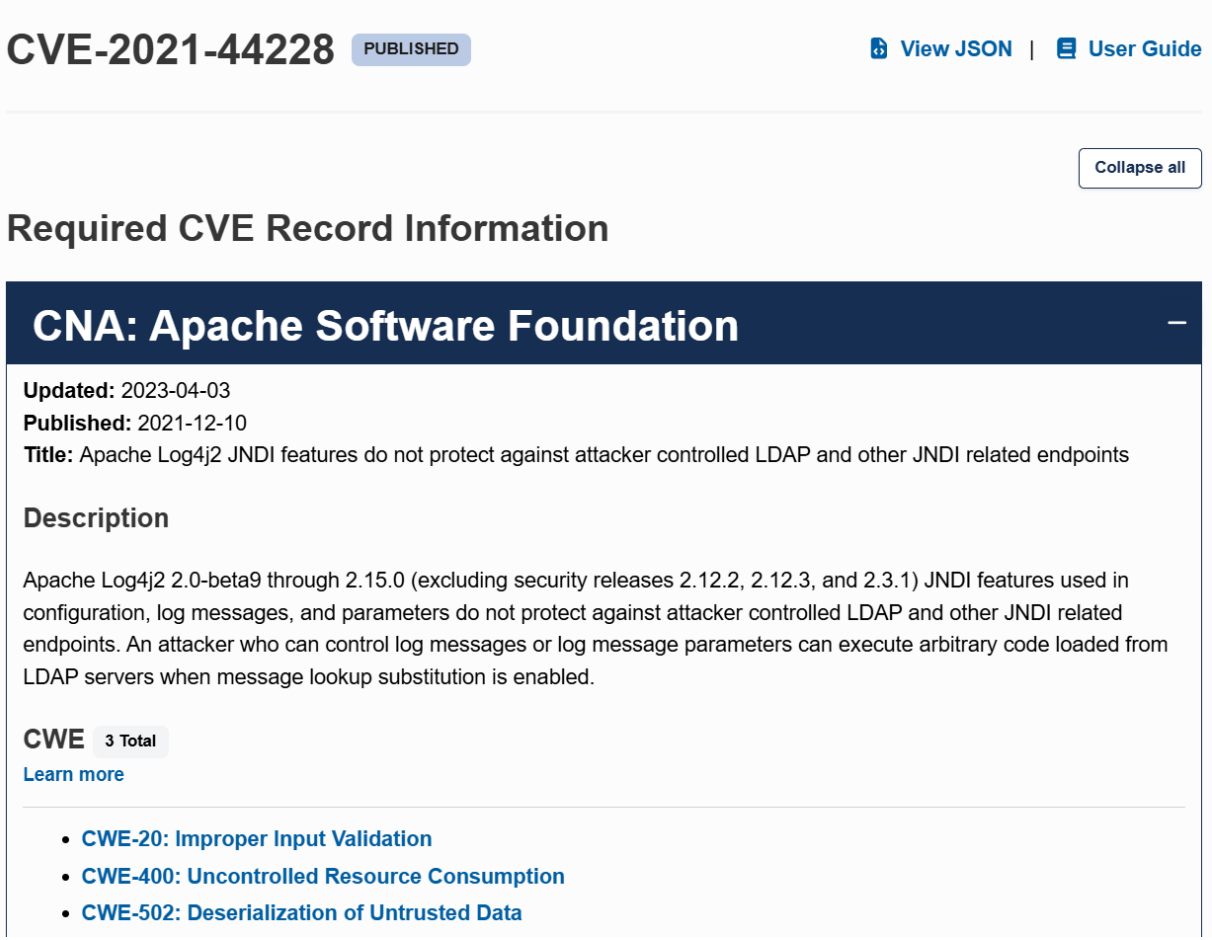
CVE

CVE (Common Vulnerabilities and Exposures) - уникальный номер, присваиваемый конкретной уязвимости в конкретном продукте

Формат: **CVE-год-номер**

Номер присваивает CNA (CVE Numbering Authority) — MITRE, крупные вендоры (Microsoft, Google, Red Hat) или проект имеют право выпускать свои CVE. Обычно процесс запускается исследователем или вендором после обнаружения уязвимости

Запись CVE обычно ссылается на один или несколько CWE



https://www.cve.org

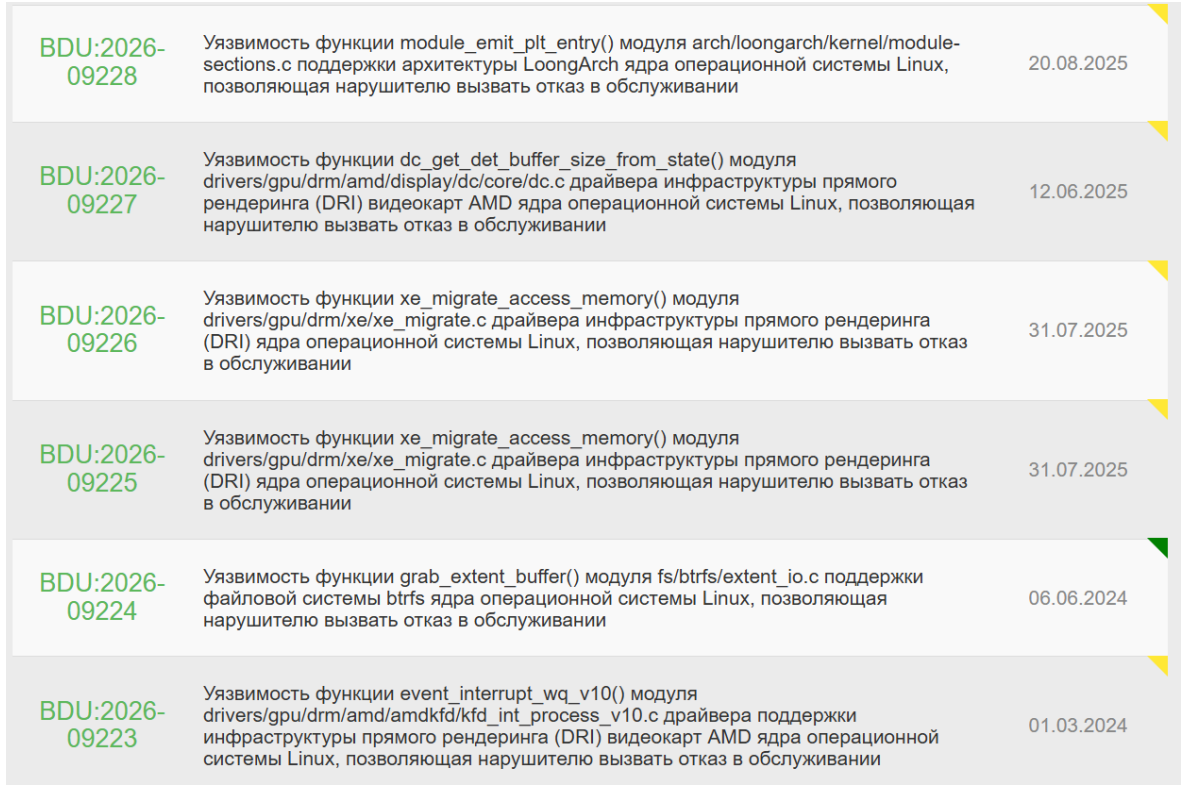
БДУ ФСТЭК

Банк данных угроз безопасности информации (БДУ) ФСТЭК России — это официальный государственный ресурс, где систематизированы сведения об угрозах безопасности информации и уязвимостях.

Идентификатор уязвимости в БДУ ФСТЭК имеет формат

BDU:YYYY-NNNNN

За присвоение идентификатора отвечает оператор БДУ (ФАУ «ГНИИИ ПТЗИ ФСТЭК России»)



BDU:2026-09228	Уязвимость функции module_emit_plt_entry() модуля arch/loongarch/kernel/module-sections.c поддержки архитектуры LoongArch ядра операционной системы Linux, позволяющая нарушителю вызвать отказ в обслуживании	20.08.2025
BDU:2026-09227	Уязвимость функции dc_get_det_buffer_size_from_state() модуля drivers/gpu/drm/amd/display/dc/core/dc.c драйвера инфраструктуры прямого рендеринга (DRI) видеокарт AMD ядра операционной системы Linux, позволяющая нарушителю вызвать отказ в обслуживании	12.06.2025
BDU:2026-09226	Уязвимость функции xe_migrate_access_memory() модуля drivers/gpu/drm/xe/xe_migrate.c драйвера инфраструктуры прямого рендеринга (DRI) ядра операционной системы Linux, позволяющая нарушителю вызвать отказ в обслуживании	31.07.2025
BDU:2026-09225	Уязвимость функции xe_migrate_access_memory() модуля drivers/gpu/drm/xe/xe_migrate.c драйвера инфраструктуры прямого рендеринга (DRI) ядра операционной системы Linux, позволяющая нарушителю вызвать отказ в обслуживании	31.07.2025
BDU:2026-09224	Уязвимость функции grab_extent_buffer() модуля fs/btrfs/extent_io.c поддержки файловой системы btrfs ядра операционной системы Linux, позволяющая нарушителю вызвать отказ в обслуживании	06.06.2024
BDU:2026-09223	Уязвимость функции event_interrupt_wq_v10() модуля drivers/gpu/drm/amd/amdkfd/kfd_int_process_v10.c драйвера поддержки инфраструктуры прямого рендеринга (DRI) видеокарт AMD ядра операционной системы Linux, позволяющая нарушителю вызвать отказ в обслуживании	01.03.2024

https://bdu.fstec.ru/vul

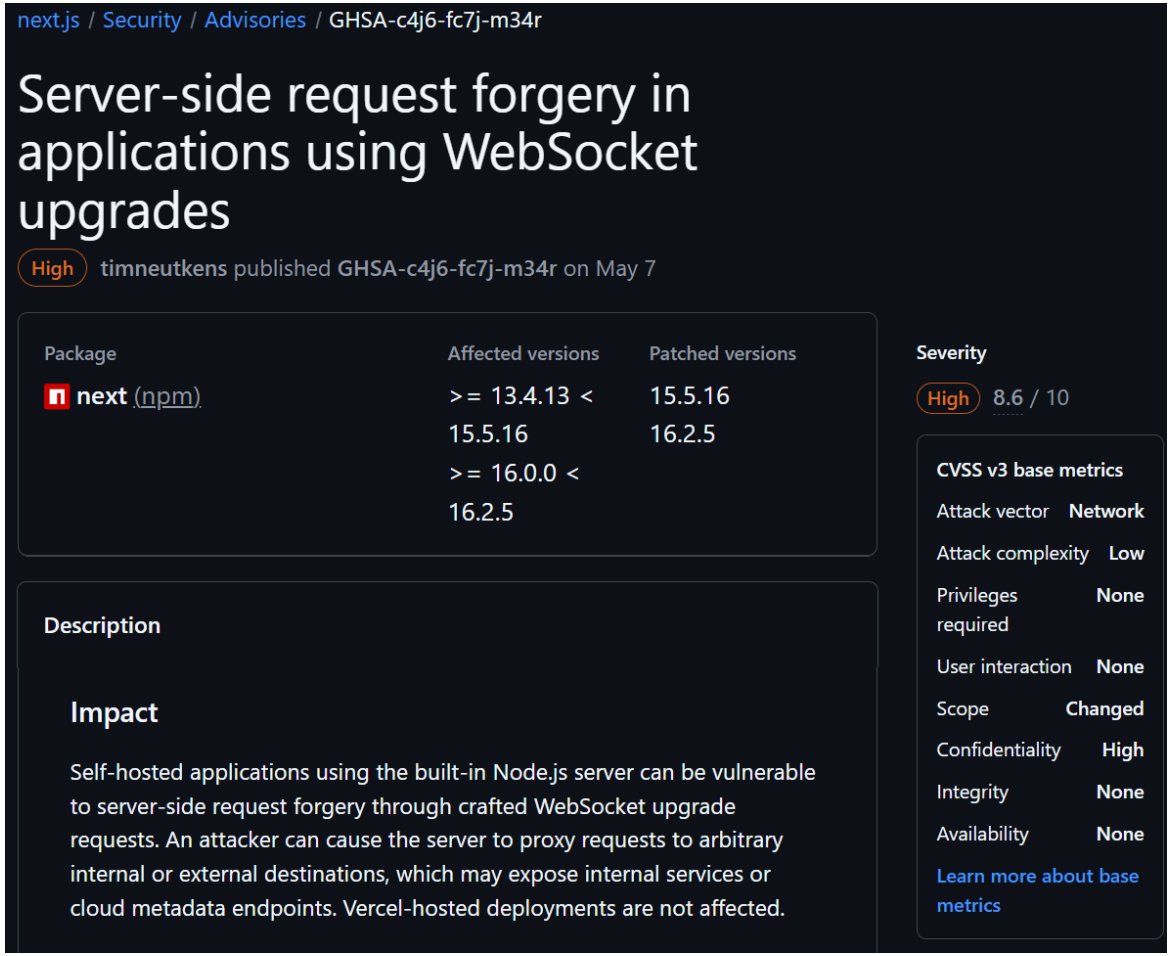
GHSA

GHSA (GitHub Security Advisory) — идентификатор уязвимости, который присваивает GitHub Advisory Database для пакетов из открытых экосистем: npm, PyPI, Maven, Go.

Формат: **GHSA-xxxx-xxxx-xxxx**

Advisory публикует мейнтейнер пакета, исследователь через GitHub Security Lab или сам GitHub на основе уже существующей CVE-записи. GitHub Advisory Database входит в число официальных CNA.

Advisory ссылается на CWE и на CVE, если запись уже существует в общей системе.

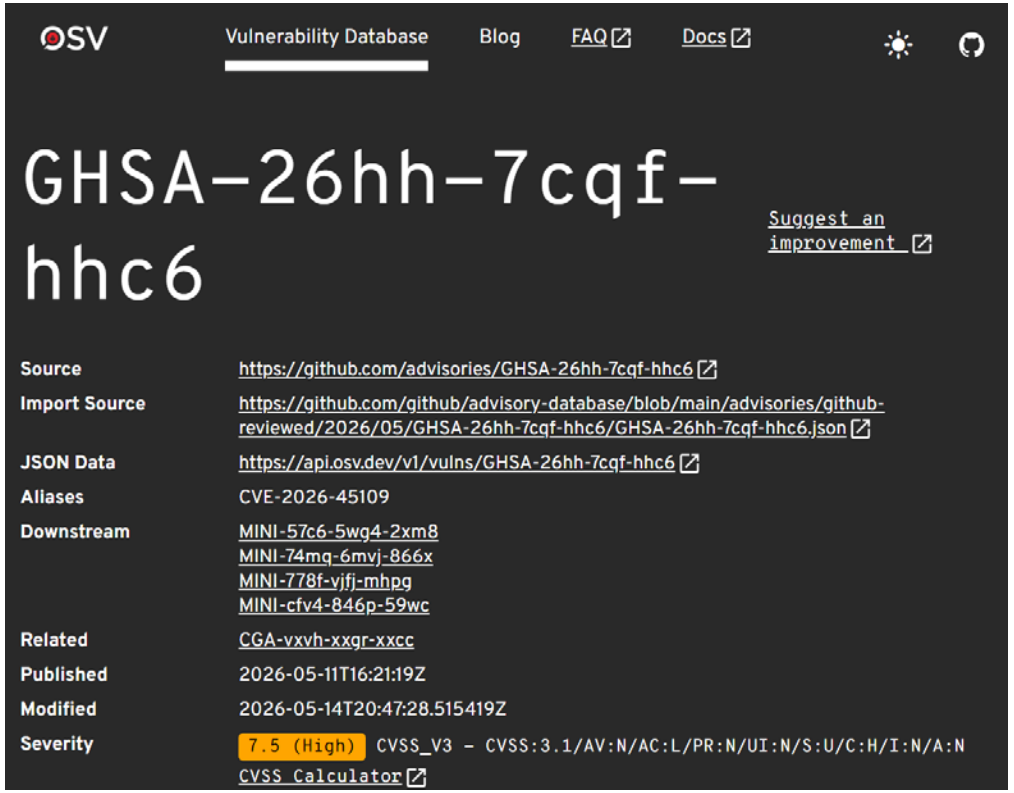


OSV

OSV (Open Source Vulnerability) – формат и база данных для уязвимостей в open-source пакетах

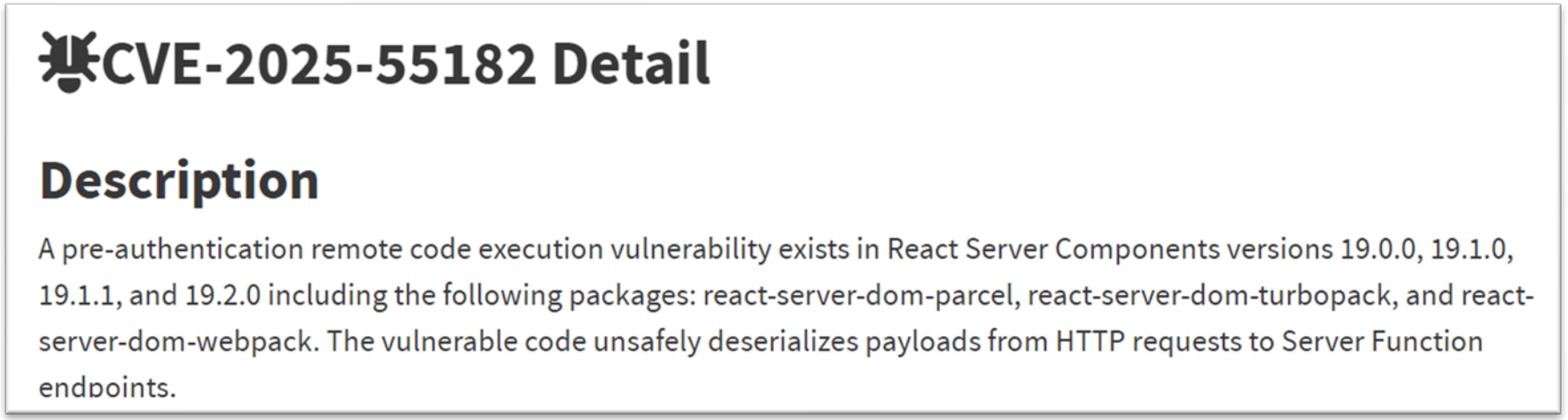
Идентификатор выглядит как **OSV-2024-1234** или сохраняет нативный номер экосистемы (например, GHSA или PYSEC), если запись пришла оттуда. OSV агрегирует данные из GHSA, PyPA Advisory Database, RustSec, Go Vulnerability Database и других источников. Запись OSV ссылается на исходный CVE или GHSA как источник.

SCA-сканеры используют эту базу как основной источник данных о зависимостях.



https://osv.dev

Пример



CVE-2025-55182 Detail

Description

A pre-authentication remote code execution vulnerability exists in React Server Components versions 19.0.0, 19.1.0, 19.1.1, and 19.2.0 including the following packages: react-server-dom-parcel, react-server-dom-turbopack, and react-server-dom-webpack. The vulnerable code unsafely deserializes payloads from HTTP requests to Server Function endpoints.

- https://www.cve.org/CVERecord?id=**CVE-2025-55182**
- https://github.com/vercel/next.js/security/advisories/**GHSA-9qr9-h5gf-34mp**
- https://bdu.fstec.ru/vul/**2025-15156**
- https://osv.dev/vulnerability/**CVE-2025-55182**

- https://cwe.mitre.org/data/definitions/**502**.html
  (Deserialization of Untrusted Data)

Базы данных уязвимостей

Источники обнаружения уязвимостей

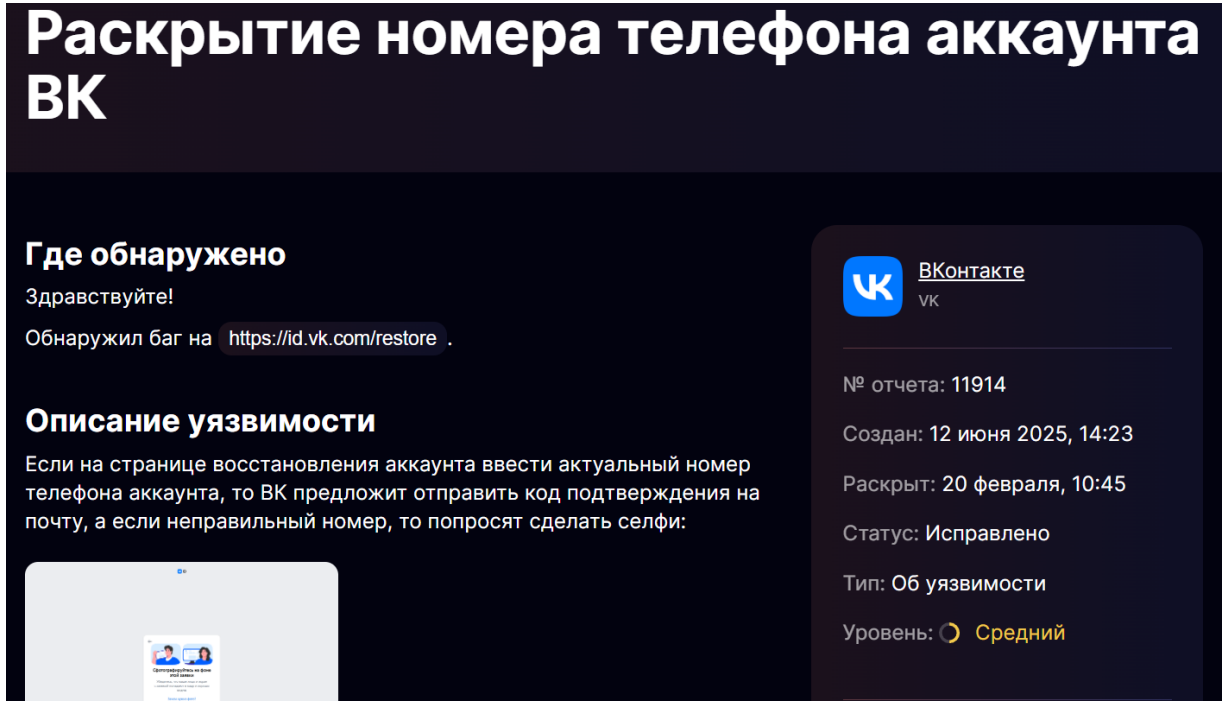
- **Исследователи безопасности**
  Независимые специалисты, например, исследователь Лахлан Дэвидсон обнаружил React2Shell и передал информацию команде Meta до публичного раскрытия
- **Bug bounty программы**
  Компании платят за найденные уязвимости через формализованные программы
- **Вендорские бюллетени**
  Сам производитель (вендор) обнаруживает проблему через внутренний аудит или от сообщения внешнего исследователя. Вендор публикует официальное уведомление с деталями и патчем

Bug bounty

Программа вознаграждения за найденные ошибки (Bug bounty): компания официально приглашает внешних исследователей безопасности искать уязвимости в ее системах и платит за подтвержденные находки

Платформы:

- Standoff 365 Bug Bounty (Россия) *bugbounty.standoff365.com*
- BI.ZONE Bug Bounty (Россия) *bugbounty.bi.zone*
- HackerOne (международная) *hackerone.com*



Хранилища данных об уязвимостях

- **CVE / NVD** [1] - (National Vulnerability Database) – американский государственный ресурс, обогащающий CVE-запись дополнительными метаданными: CVSS-баллом (критичностью), списком затронутых продуктов, ссылками на патчи
- **OSV** [2] - агрегатор для open-source экосистем в едином машиночитаемом формате. Собирает данные из GHSA, PyPA, RustSec и других источников экосистем, приводя их к общей структуре для потребления инструментами
- **GitHub Advisory Database** [3] - хранилище, специфичное для пакетов, размещенных на GitHub
- **БДУ ФСТЭК** [4] - официальный государственный ресурс, где систематизированы сведения об угрозах и уязвимостях

1. https://nvd.nist.gov
2. https://osv.dev
3. https://github.com/advisories
4. https://bdu.fstec.ru/vul

Каналы получения информации об уязвимостях

- **Дайджесты**
  Еженедельные или ежедневные подборки новых критичных уязвимостей с кратким описанием и ссылками
  Например, ФинЦЕРТ дайджест Банка России [1]
- **Подписки на конкретные продукты**
  GitHub Dependabot, Snyk и аналогичные сервисы отслеживают зависимости конкретного проекта и присылают алерты
- **Профессиональные каналы**
  Telegram-каналы, Twitter/X-аккаунты исследователей, блоги security-вендоров (Wiz, Google Cloud Threat Intelligence, Sophos) - источник быстрой первичной информации, часто раньше официальной публикации в NVD

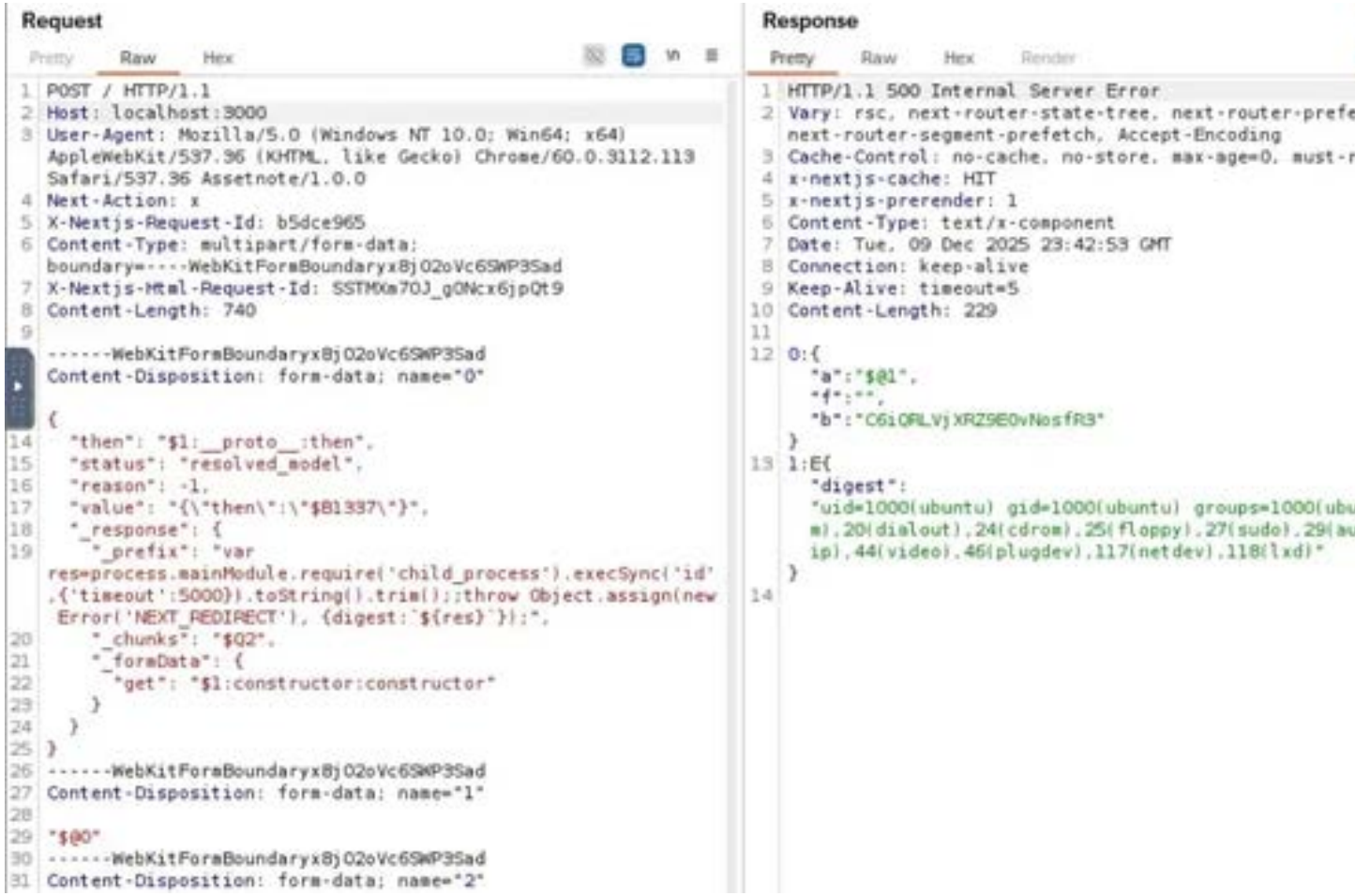
1 - https://cbr.ru/information_security/fincert/

Оценка критичности

React2shell

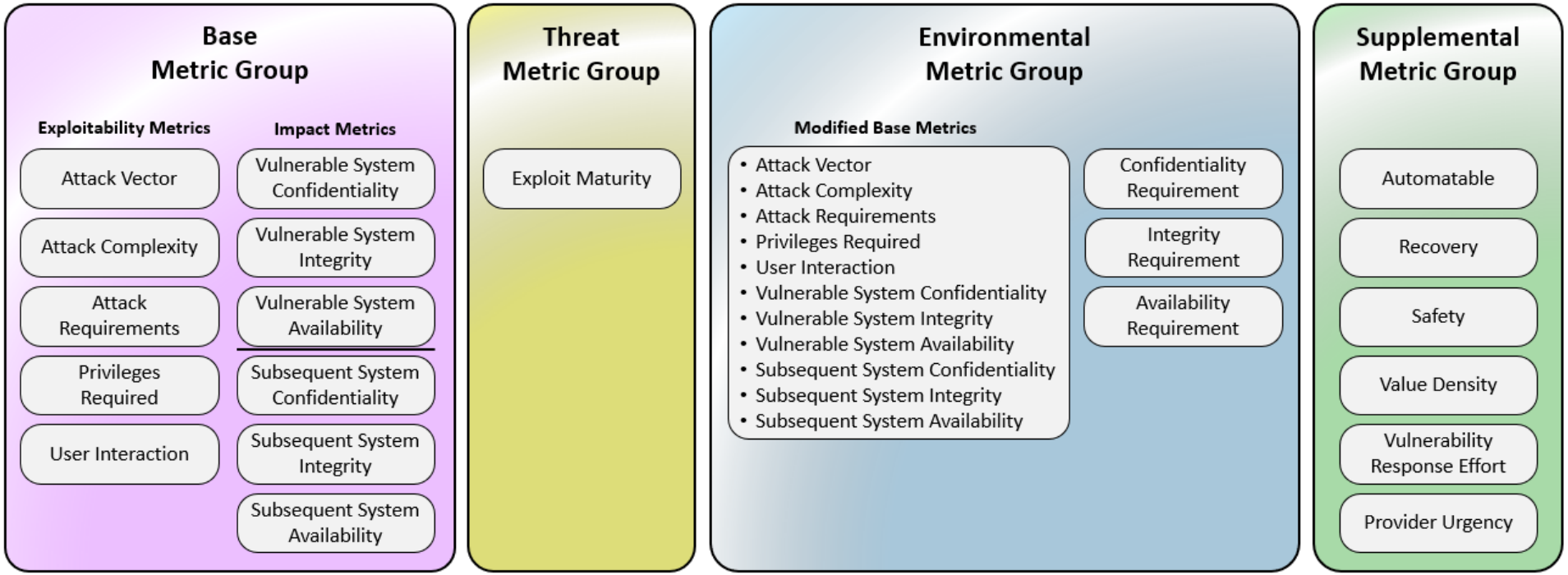
CVE-2025-55182 - критическая уязвимость в библиотеке React. Позволяет выполнять произвольный код (**RCE** - **Remote Code Execution**) на атакуемом сервере

Вектор эксплуатации
Один специально сформированный HTTP-запрос к серверному компоненту, не требующий аутентификации



Common Vulnerability Scoring System

Стандарт для расчета численной оценки серьезности уязвимости от 0 до 10. Актуальная версия - CVSS 4.0



Attack Vector - Вектор атаки (AV)

- **Network** - через интернет или локальную сеть
  Пример: React2Shell (CVE-2025-55182). Один HTTP-запрос с любого адреса в интернете выполняет код на сервере
- **Adjacent** - требует физического или логического присутствия в конкретном сетевом сегменте (Wi-Fi, локальная сеть, VPN)
  Пример: Уязвимость в протоколе WPA2 позволяет перехватывать трафик, но атакующему нужно находиться в радиусе действия Wi-Fi-сети жертвы
- **Local** - нужен локальный доступ к системе (возможность запустить процесс локально, SSH-сессия)
  Пример: уязвимости в системной службе операционной системы,
- **Physical** - нужен физический контакт с устройством
  Пример: DMA-атака через порт Thunderbolt

Attack Complexity – Сложность атаки (AC)

Оценка сложности проведения атаки

Low - эксплойт срабатывает стабильно при стандартных условиях

- *Пример: React2Shell (CVE-2025-55182). Стандартное приложение Next.js уязвимо без особых настроек, один запрос срабатывает каждый раз*

High - нужно обойти защиту, подобрать вариант эксплойта

- *Пример: предсказуемый токен сброса пароля*

Attack Requirements – Требования к атаке (AT)

Нужны ли особые условия на стороне цели атаки

None - эксплойт работает против системы в обычном состоянии

Present - нужны особые условия:

- **Состояние гонки**
  Проверка и действие идут двумя отдельными шагами. Между ними образуется окно, и параллельные запросы успевают в него попасть
- **Нестандартная конфигурация**
  Уязвимость проявляется, только если включена определенная, не дефолтная настройка
- **Позиция MitM**
  Атакующий должен находиться между клиентом и сервером, например, в том же публичном Wi-Fi, и перехватывать трафик

Privileges Required – Уровень привилегий (PR)

Уровень доступа, которым атакующий должен обладать до начала атаки

- **None** - доступ не нужен вообще
  Пример: React4Shell
- **Low** - базовый пользовательский аккаунт
  Пример: IDOR
- **High** - административные или иные повышенные права
  Пример: админ-панель

User Interaction – Взаимодействие с пользователем (UI)

Требуется ли действие другого человека
для срабатывания атаки

- **None** - атака проходит полностью силами атакующего
- **Passive** - жертва выполняет обычное действие, которое запускает эксплойт
  например: открывает страницу, читает письмо
- **Active** - жертва совершает специфичное действие, направленное на срабатывание эксплойта
  например: кликает по ссылке, устанавливает файл

Метрики воздействия на систему

Оценивают последствия успешной эксплуатации в разрезе:

- Vulnerable System - самой уязвимой системы
- Subsequent System - системы, до которых можно дотянуться через нее

	Конфиденциальность VC / SC	**Целостность VI / SI**	**Доступность VA / SA**
	Возможность доступа к данным	Возможность модификации данных	Доступность сервиса для клиентов
None	Нет доступа	Нет	Нет влияния
Low	Частичный	Ограничена	Частичная недоступность
High	Полный	Полная	Полный отказ

Примеры

React2Shell

AV - Network, AC - Low, AT - None, PR - None, UI – None

Confidentiality – High, Integrity – High, Availability - High

CVE-2026-43503

AV - Local, AC - Low, AT - None, PR - Low, UI – None

Confidentiality – High, Integrity – High, Availability - High

CVE-2026-43503 DirtyClone

Уязвимость сетевого компонента skbuff ядра операционных систем Linux. Уязвимость относится к семейству DirtyFrag - классу проблем в сетевом стеке ядра Linux, связанных с обработкой socket buffer. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии

Требуется CAP_NET_ADMIN. Непривилегированный пользователь получает его в собственном user namespace, если namespaces включены (так настроено по умолчанию во многих дистрибутивах)

Результат эксплуатации - root-доступ, что дает полный контроль над конфиденциальностью, целостностью и доступностью системы

CVSS 4.0: AV:L/AC:L/AT:N/PR:L/UI:N/S:C/C:H/I:H/A:H

Контекстные метрики

- **Требования безопасности**
- **Модифицированные базовые метрики**

Контекстные метрики

Требования безопасности (CR, IR, AR):

Задают важность каждого из трех свойств именно для этой организации

Требования безопасности

Требования к конфиденциальности (CR):			
Не определены (X)	Высокие (H)	Средние (M)	Низкие (L)

Требования к целостности (IR):			
Не определены (X)	Высокие (H)	Средние (M)	Низкие (L)

Требования к доступности (AR):			
Не определены (X)	Высокие (H)	Средние (M)	Низкие (L)

Контекстные метрики

Модифицированные базовые метрики

Показатели возможности эксплуатации

Вектор атаки (корр.) (MAV):

Не определено (X	Сетевой (N)	Смежный (A)	Локальный (L)	Физический (P)

Сложность атаки (корр.) (MAC):

Не определено (X)	Низкая (L)	Высокая (H)

Требования к атаке (корр.) (MAT):

Не определено (X)	Отсутствуют (N)	Существуют (P)

Уровень привилегий (корр.) (MPR):

Не определено (X)	Не требуется (N)	Низкий (L)	Высокий (H)

Взаимодействие с пользователем (корр.) (MUI):

Не определено (X)	Не требуется (N)	Пассивное (P)	Активное (A)

Показатели воздействия на уязвимую систему

Влияние на конфиденциальность (корр.) (MVC):

Не определено (X)	Высокое (H)	Низкое (L)	Не оказывает (N)

Влияние на целостность (корр.) (MVI):

Не определено (X)	Высокое (H)	Низкое (L)	Не оказывает (N)

Влияние на доступность (корр.) (MVA):

Не определено (X)	Высокое (H)	Низкое (L)	Не оказывает (N)

Показатели воздействия на последующие системы

Влияние на конфиденциальность (корр.) (MSC):

Не определено (X)	Высокое (H)	Низкое (L)	Не оказывает (N)

Влияние на целостность (корр.) (MSI):

Не определено (X	Угроза безопасно	Высокое (H)	Низкое (L)	Не оказывает (N)

Влияние на доступность (корр.) (MSA):

Не определено (X	Угроза безопасно	Высокое (H)	Низкое (L)	Не оказывает (N)

Пример контекстных метрик

Вектор атаки

Уязвимость с базовым AV:N (сеть) в изолированном сегменте без внешнего доступа получает MAV:Adjacent (смежный) - сетевой интерфейс закрыт маршрутизатором, поверхность атаки сужена

Влияние на целостность

Уязвимость с базовым VI:H (атакующий может менять файлы), но файловая система смонтирована только для чтения - получаем MVI:N (нет влияния на целостность)

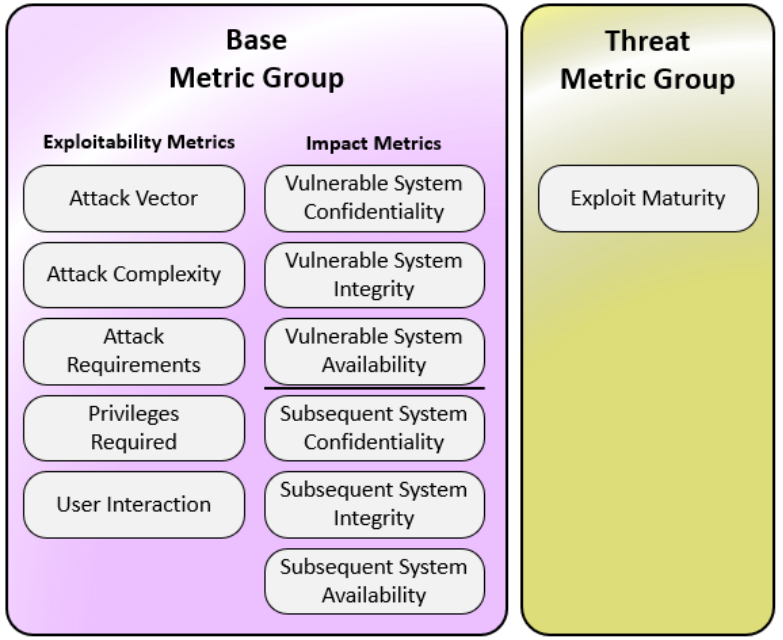
Метрика угроз: Exploit Maturity (E)

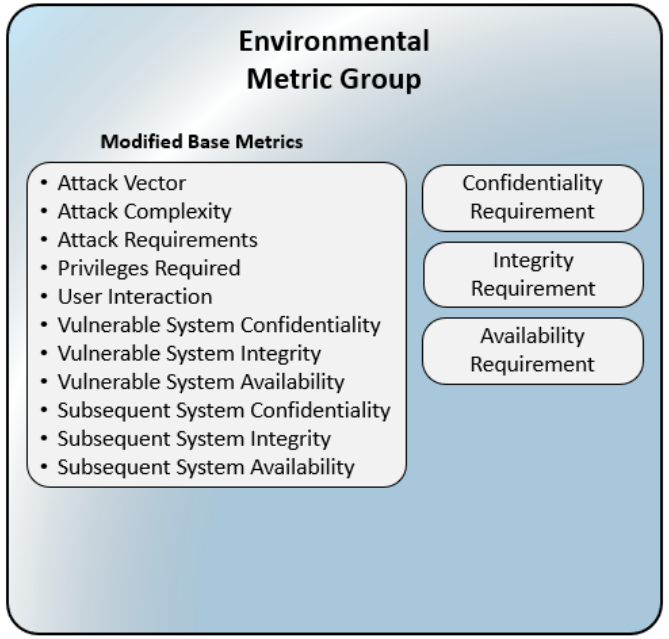
Оценивает состояние доступных методов эксплуатации уязвимости на текущий момент

- **Attacked (A)**
  Зафиксированы случаи активной эксплуатации в реальных атаках
- **POC (P)**
  Существует публичный proof-of-concept: рабочий код или подробное описание, демонстрирующее эксплуатацию, но без подтвержденных атак в реальных условиях
- **Unreported (U)**
  Достоверных данных об эксплойте или атаках нет. Значение по умолчанию для только что раскрытой уязвимости

CVSS - выводы

- CVSS стандартизирует оценку уязвимости в виде числа и вектора
- Base Score остается неизменным для системы вне зависимости от контекста
- Контекстные и метрики угроз адаптируют оценку критичности под конкретную организацию в конкретный момент





Оценка вероятности эксплуатации

EPSS: вероятность эксплуатации

EPSS (Exploit Prediction Scoring System) - модель, оценивающая вероятность реальной эксплуатации конкретной уязвимости.

Метрика имеет два показателя:

Score - вероятность эксплуатации уязвимости в ближайшие 30 дней. Значение - число от 0 до 1

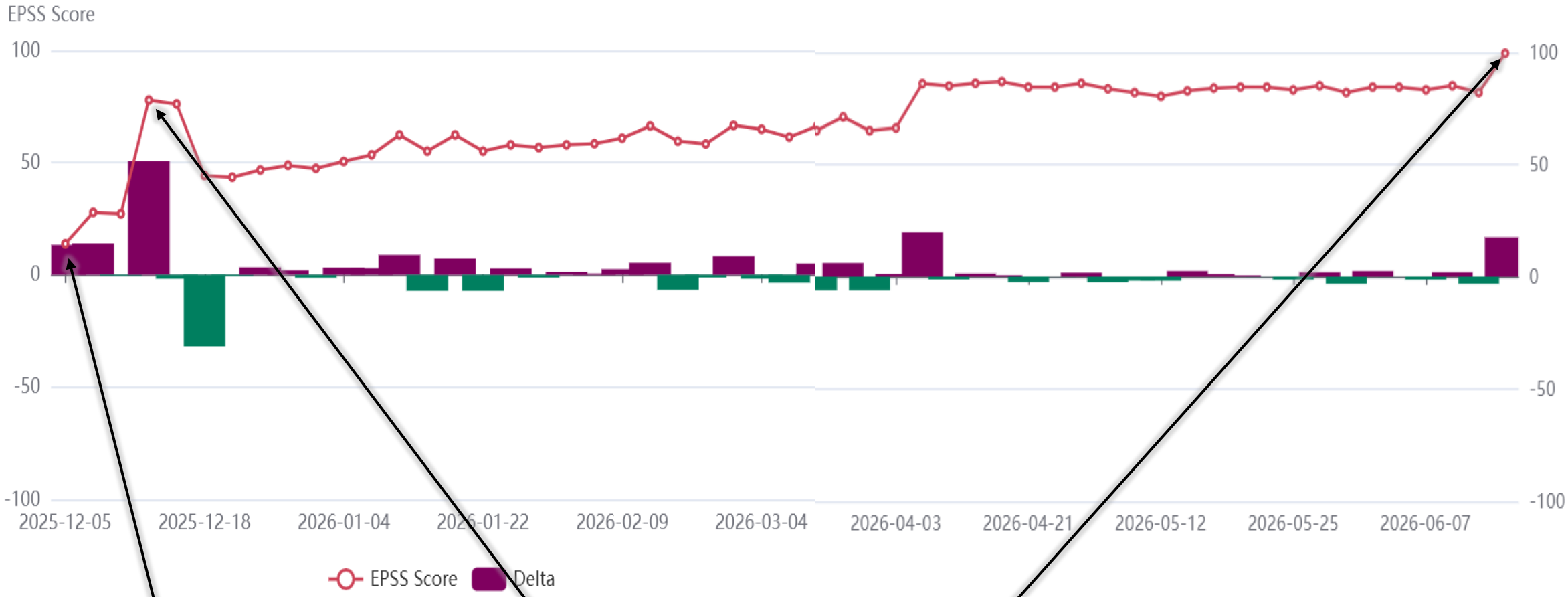
Percentile - положение уязвимости относительно всех остальных CVE в системе EPSS на данный момент. Значение - число от 0 до 100%

Модель машинного обучения тренирована на исторических данных – уязвимостях, которые эксплуатировались в дикой природе, их характеристиках. Входные признаки включают наличие публичного PoC, упоминания в соцсетях и на форумах, тип уязвимого ПО, возраст CVE, активность сканеров в интернете. FIRST пересчитывает баллы ежедневно по мере поступления новых данных.

Динамика EPSS

CVE-2025-55182 EPSS score history

https://www.cvedetails.com/epss/CVE-2025-55182/epss-score-history



13.81%

первая реакция модели

77.80%

публичные PoC и атаки

99.56%

почти гарантированная эксплуатация

CISA KEV – Known Exploited Vulnerabilities

CISA KEV — каталог уязвимостей, которые Агентство кибербезопасности и защиты инфраструктуры США (CISA) официально подтвердило как активно эксплуатируемые злоумышленниками в реальных атаках

KEV = доказанная эксплуатация

CVSS **6.5**

KEV

>

приоритет

CVSS **9.5**

not KEV

NVD Vulnerability Search

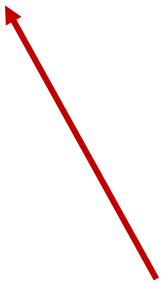
CVE-2025-55182

Advanced | Reset | Show Statistics

For a phrase search, use " "

Keyword: CVE-2025-55182 ⊗

Identifier	CISA Kev Info	Published Date	CNA	Description
CVE-2025-55182	☑	Dec 03, 2025	Facebook, Inc.	A pre-authentication remote code execution vulnerability exists in React Server Components versions 19.0.0, 19.1.0, 19.1.1, and 19.2.0 including the following packages: react-server-dom-parcel, react-server-dom-turbopack, and react-server-dom-webpack. The vulnerable code unsafely deserializes payloa ...



есть запись в базе CISA KEV

2025 CWE Top 25 Most Dangerous Software Weaknesses

Top 25 Home | Share via: X | View in table format | Key Insights | Methodology

1 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')
CWE-79 | CVEs in KEV: 7 | Rank Last Year: 1

2 Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
CWE-89 | CVEs in KEV: 4 | Rank Last Year: 3 (up 1) ▲

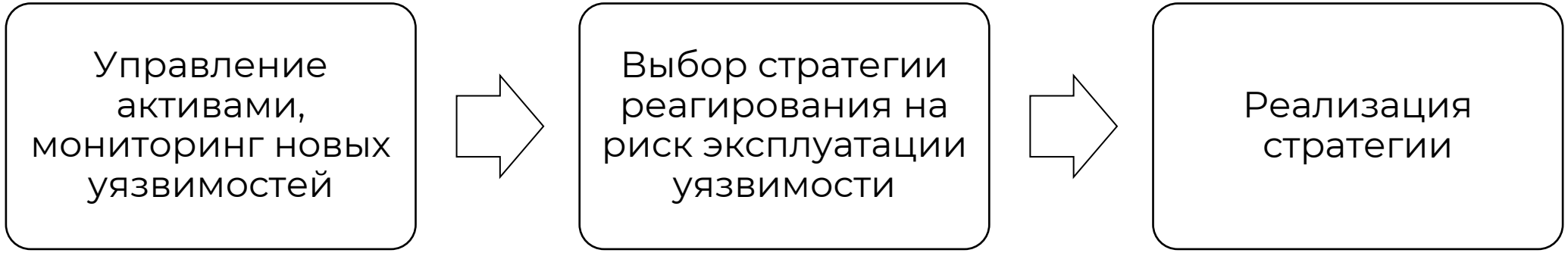
3 Cross-Site Request Forgery (CSRF)
CWE-352 | CVEs in KEV: 0 | Rank Last Year: 4 (up 1) ▲

4 Missing Authorization
CWE-862 | CVEs in KEV: 0 | Rank Last Year: 9 (up 5) ▲

5 Out-of-bounds Write
CWE-787 | CVEs in KEV: 12 | Rank Last Year: 2 (down 3) ▼

Управление уязвимостями

Системная работа с уязвимостями



NIST SP 800-40
Guide to Enterprise Patch Management Planning — документ Национального института стандартов и технологий США (NIST), описывающий жизненный цикл управления уязвимостями ПО

Этап 1: Управление активами, мониторинг уязвимостей

Инвентаризация активов

- Приложения и их зависимости (SBOM)
- Базы данных и хранилища
- Инфраструктура (серверы, контейнеры, облака)
- Владелец актива
- Критичность актива для компании
- Применяемые средства защиты
- ...

Непрерывный мониторинг уязвимостей

- Источники данных: CVE/NVD, OSV, GitHub Advisory Database, дайджесты и подписки, платные фиды

Этап 2: Выбор стратегии реагирования

- **Принятие риска**

  Осознанное понимание наличия незакрытых уязвимостей, ожидаемый ущерб от эксплуатации которых достаточно низок
- **Минимизация/митигация риска**

  Устранение уязвимости и/или минимизация риска путем применения дополнительных мер защиты
- **Передача риска**

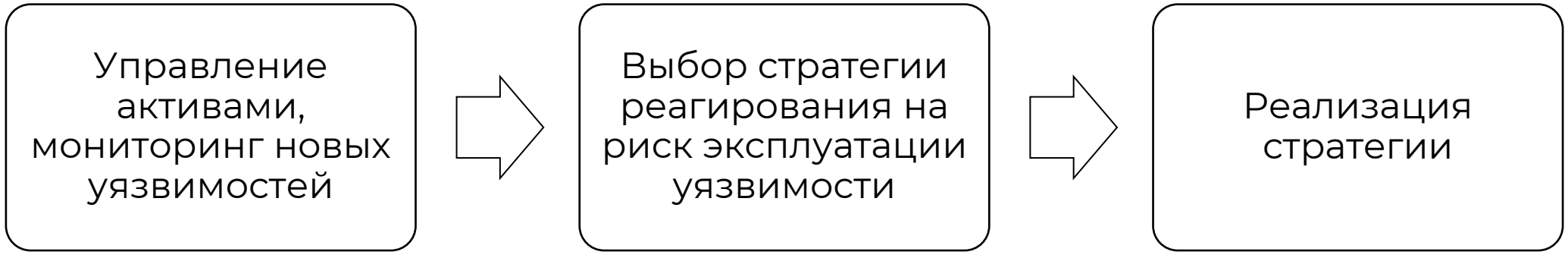
  Риск передается на третью сторону (киберстрахование, договорные обязательства вендора, аутсорсинг)
- **Избегание риска**

  Удаление уязвимого ПО, отключение уязвимого компонента, вывод из эксплуатации системы

Этап 3: Реализация стратегии реагирования

1. Подготовка к установке обновлений
2. Развертывание
3. Проверка установленного обновления
4. Мониторинг

Пример



Актив:
Веб-приложение А

Уязвимость:
IDOR в методе
GET /api/orders/{id}

Минимизация:
- Rate-limiting

Митигация:
Исправление уязвимости в коде

- AppSec передает разработчику
- Разработчик исправляет уязвимость
- AppSec верифицирует

Оценка критичности:
CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N/CR:H **7.1 / Высокая**

Пример

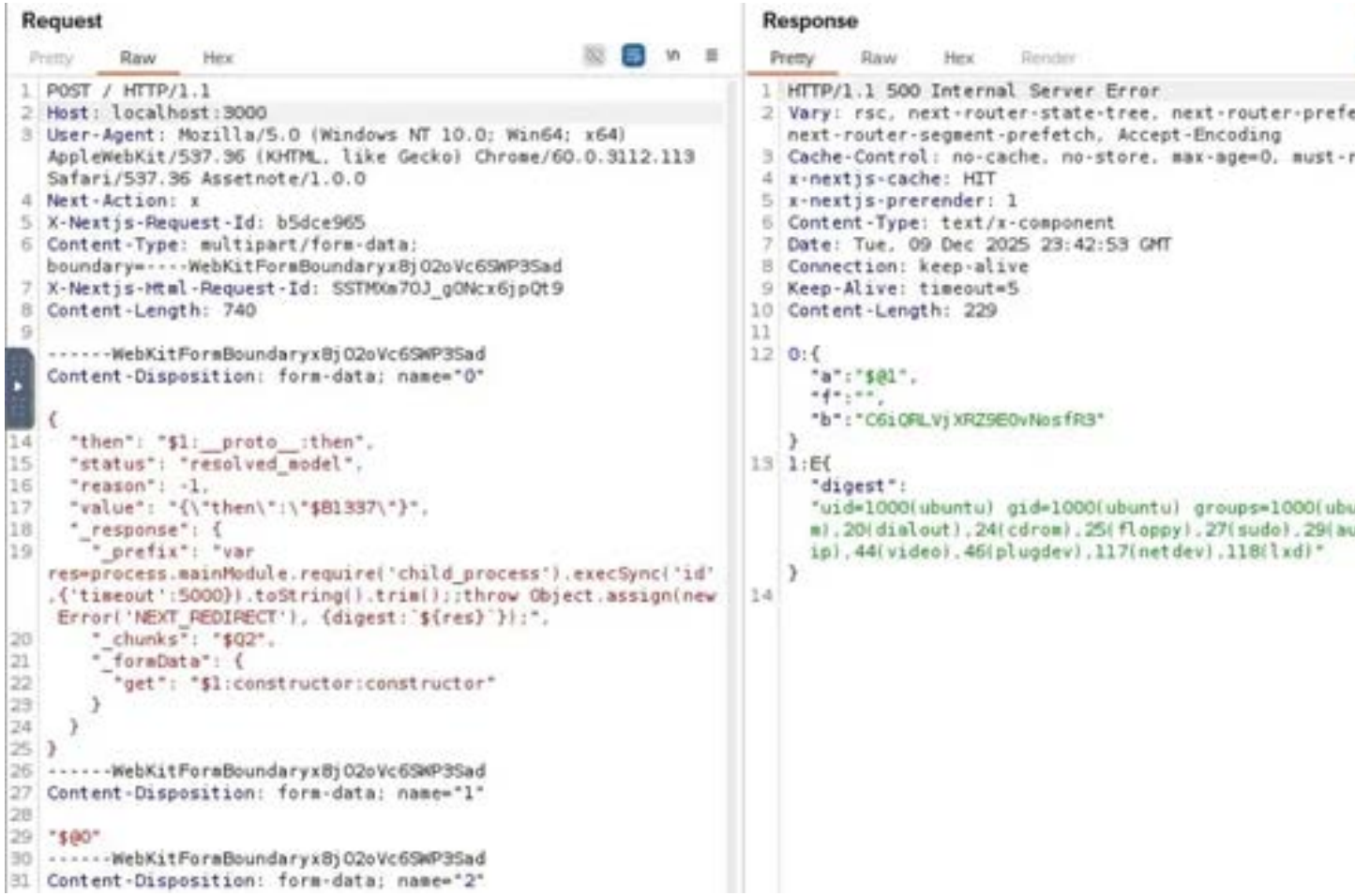
React2shell

Разберем сценарий реагирования на уязвимость
до эксплуатации в рамках процесса управления уязвимостями

React2shell

CVE-2025-55182 - критическая уязвимость в библиотеке React. Позволяет выполнять произвольный код (**RCE** - **Remote Code Execution**) на атакуемом сервере

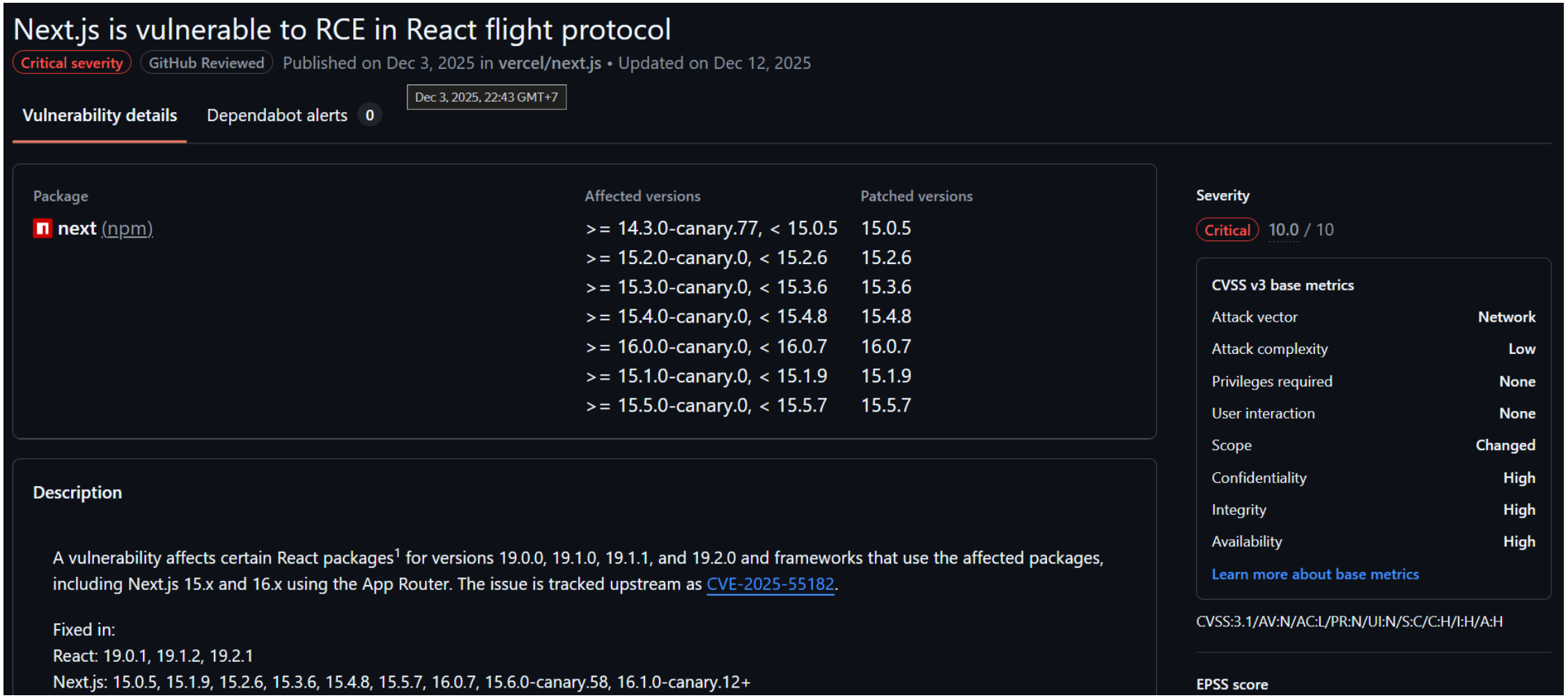
Вектор эксплуатации
Один специально сформированный HTTP-запрос к серверному компоненту, не требующий аутентификации



Канал обнаружения

- Публикация в блогах
- Advisory GHSA-9qr9-h5gf-34mp
- Вендорский бюллетень от Vercel https://vercel.com/changelog/cve-2025-55182
- Алерт от инструмента проверки зависимостей (SCA)

Advisory GHSA-9qr9-h5gf-34mp



Next.js is vulnerable to RCE in React flight protocol

Critical severity | GitHub Reviewed | Published on Dec 3, 2025 in vercel/next.js • Updated on Dec 12, 2025

Vulnerability details | Dependabot alerts 0

Dec 3, 2025, 22:43 GMT+7

Package	Affected versions	Patched versions
next (npm)	>= 14.3.0-canary.77, < 15.0.5	15.0.5
	>= 15.2.0-canary.0, < 15.2.6	15.2.6
	>= 15.3.0-canary.0, < 15.3.6	15.3.6
	>= 15.4.0-canary.0, < 15.4.8	15.4.8
	>= 16.0.0-canary.0, < 16.0.7	16.0.7
	>= 15.1.0-canary.0, < 15.1.9	15.1.9
	>= 15.5.0-canary.0, < 15.5.7	15.5.7

Description

A vulnerability affects certain React packages[1] for versions 19.0.0, 19.1.0, 19.1.1, and 19.2.0 and frameworks that use the affected packages, including Next.js 15.x and 16.x using the App Router. The issue is tracked upstream as CVE-2025-55182.

Fixed in:
React: 19.0.1, 19.1.2, 19.2.1
Next.js: 15.0.5, 15.1.9, 15.2.6, 15.3.6, 15.4.8, 15.5.7, 16.0.7, 15.6.0-canary.58, 16.1.0-canary.12+

Severity

Critical 10.0 / 10

CVSS v3 base metrics

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Changed
Confidentiality	High
Integrity	High
Availability	High

Learn more about base metrics

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

EPSS score

https://github.com/advisories/GHSA-9qr9-h5gf-34mp

Вендорский бюллетень

Blog / Changelog

Summary of CVE-2025-55182

Aaron Brown, Jimmy Lai, Luba Kravchenko, Sage Abraham, Andy Riancho

See the React2Shell security bulletin for the latest updates.

Summary

A critical-severity vulnerability in React Server Components (CVE-2025-55182) affects React 19 and frameworks that use it, including Next.js (CVE-2025-66478). Under certain conditions, specially crafted requests could lead to unintended remote code execution.

We created new rules to address this vulnerability and quickly deployed to the Vercel WAF to automatically protect all projects hosted on Vercel at no cost. However, do not rely on the WAF for full protection. Immediate upgrades to a patched version are required. We also worked with the React team to deliver recommendations to the largest WAF and CDN providers.

Impact

Applications using affected versions of the React Server Components implementation may process untrusted input in a way that allows an attacker to perform remote code execution. The vulnerability is present in versions 19.0, 19.1.0, 19.1.1, and 19.2.0 of the following packages: :

- react-server-dom-parcel (19.0.0, 19.1.0, 19.1.1, and 19.2.0)
- react-server-dom-webpack (19.0.0, 19.1.0, 19.1.1, and 19.2.0)
- react-server-dom-turbopack (19.0.0, 19.1.0, 19.1.1, and 19.2.0)

These packages are included in the following frameworks and bundlers:

- Next.js with versions ≥14.3.0-canary.77, ≥15 and ≥16
- Other frameworks and plugins that embed or depend on React Server Components implementation (e.g., Vite, Parcel, React Router, RedwoodSDK, Waku)

https://vercel.com/changelog/cve-2025-55182

Определение уязвимых активов

Уязвимые версии

- react-server-dom-parcel (19.0.0, 19.1.0, 19.1.1, and 19.2.0)
- react-server-dom-webpack (19.0.0, 19.1.0, 19.1.1, and 19.2.0)
- react-server-dom-turbopack (19.0.0, 19.1.0, 19.1.1, and 19.2.0)
- Next.js ≥14.3.0-canary.77, ≥15 and ≥16

Патченые версии

- **React**: 19.0.1, 19.1.2, 19.2.1
- **Next.js**: 15.0.5, 15.1.9, 15.2.6, 15.3.6, 15.4.8, 15.5.7, 15.6.0-canary.58, 16.0.7

Оценка по CVSS

Базовая критичность

- CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H **10.0**

Метрика угроз - доступность средств эксплуатации

- Attacked - **10.0 -> 10.0**
- Есть POC - **10.0 -> 9.3**
- Теоретическая (Unreported) - **10.0 -> 9.1**

Контекстные метрики

Сервис доступен из интернета – MAV:N

Требования безопасности – высокие по всем критериям

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H/CR:H/IR:H/AR:H/
MAV:N/MAC:L/MAT:N/MPR:N/MUI:N/MVC:H/MVI:H/MVA:H 10.0

Выбор стратегии

- **Принятие риска**
  - Не подходит, риск критический
- **Минимизация/митигация риска**
  - Применение дополнительных мер защиты – реализация правила на WAF
  - Обновление до неуязвимой версии

  Передача риска
  - Не применимо
- **Избегание риска**
  - Не применимо

Проекты > Shop Web > SEC-142

Обновить **Next.js** до исправленной версии (GHSA-9qr9-h5gf-34mp)

К выполнению | Вложить | Связать

Описание

Проект	shop-web (публичное веб-приложение)
Библиотека	`next` 15.x → 15.5.7
	`react-server-dom-*` → 19.2.1
Причина	CVE-2025-55182: удалённое выполнение кода без аутентификации, CVSS 10.0

Готово, когда

- [ ] Новая версия работает в продакшене
- [ ] Повторный скан не находит уязвимость

Детали

Приоритет	Критический
SLA	Часы
Исполнитель	РП Разработчик
Автор	AS AppSec
Метки	security, dependencies, CVE-2025-55182

Перерасчет после WAF

MAV:N

WAF не меняет физическую или логическую доступность цели
Запросы к приложению всн еще приходят по сети

MAC:L -> MAC:H

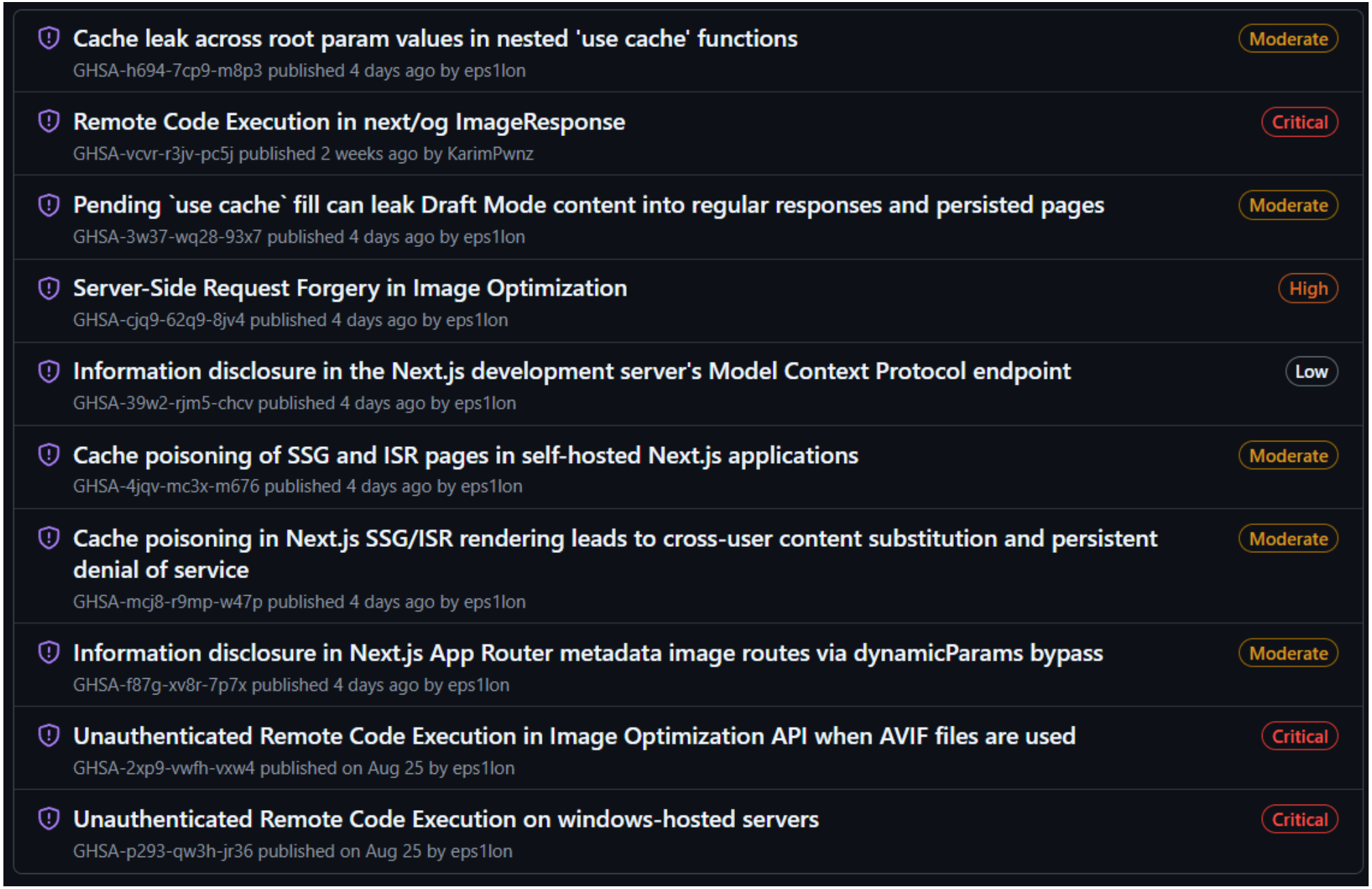
До WAF эксплойт срабатывал стабильно при любых стандартных условиях (AC:L), а теперь атакующему нужно обойти фильтрацию

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H/
CR:H/IR:H/AR:H/MAV:N/**MAC:H**/MAT:N/MPR:N/MUI:N

10.0 -> 9.5

Мониторинг после фикса

- Проверяем, что уязвимость больше не воспроизводится
- Реализуем alert на попытки эксплуатации
  при блокировке WAF запроса по паттерну


Cache leak across root param values in nested 'use cache' functions
Moderate
GHSA-h694-7cp9-m8p3 published 4 days ago by eps1lon
Remote Code Execution in next/og ImageResponse
Critical
GHSA-vcvr-r3jv-pc5j published 2 weeks ago by KarimPwnz
Pending `use cache` fill can leak Draft Mode content into regular responses and persisted pages
Moderate
GHSA-3w37-wq28-93x7 published 4 days ago by eps1lon
Server-Side Request Forgery in Image Optimization
High
GHSA-cjq9-62q9-8jv4 published 4 days ago by eps1lon
Information disclosure in the Next.js development server's Model Context Protocol endpoint
Low
GHSA-39w2-rjm5-chcv published 4 days ago by eps1lon
Cache poisoning of SSG and ISR pages in self-hosted Next.js applications
Moderate
GHSA-4jqv-mc3x-m676 published 4 days ago by eps1lon
Cache poisoning in Next.js SSG/ISR rendering leads to cross-user content substitution and persistent denial of service
Moderate
GHSA-mcj8-r9mp-w47p published 4 days ago by eps1lon
Information disclosure in Next.js App Router metadata image routes via dynamicParams bypass
Moderate
GHSA-f87g-xv8r-7p7x published 4 days ago by eps1lon
Unauthenticated Remote Code Execution in Image Optimization API when AVIF files are used
Critical
GHSA-2xp9-vwfh-vxw4 published on Aug 25 by eps1lon
Unauthenticated Remote Code Execution on windows-hosted servers
Critical
GHSA-p293-qw3h-jr36 published on Aug 25 by eps1lon

Вопросы